

MEHER SUDHAKAR ABBIREDDI

(240) 340-0064 | msabbi2022@gmail.com | linkedin.com/in/meher-sudhakar | github.com/Mehersudhakar | mehersudhakar.vercel.app

PROFESSIONAL SUMMARY

Offensive security engineer with 3+ years of red team operations, penetration testing, and vulnerability research focused on exploiting privacy weaknesses in AI-enabled and web systems. Runs hands-on offensive privacy testing that surfaces unauthorized data access and data-exfiltration paths, then drives remediation with engineering and product teams. Plans campaign-style red team operations and builds AI-driven offensive agents in Python. Independently surfaced 30+ confirmed vulnerabilities exposing private data, including a novel Denial-of-Wallet class on a production RAG pipeline. Holds 7 assigned CVEs for independently discovered vulnerabilities in widely deployed software, each runtime-confirmed before disclosure. Certified eJPT, Security+, and CEH, currently pursuing OSCP.

SECURITY RESEARCH

Stored XSS to Account Takeover | CVE-2026-11766

WPScan

- Seized full **account takeover** of higher-privileged users from a Subscriber-level **stored XSS** (CWE-79, CVSS 8.0) in a 200,000+ install plugin, exposing the private account data a **privacy threat actor** would harvest.
- Reproduced the takeover on a clean bench where output-side entity decoding reversed input **sanitization**, then coordinated **responsible disclosure** through WPScan with the CVE assigned.

Unauthenticated PHP Object Injection | CVE-2026-12081

WPScan

- Reported an unauthenticated **PHP object injection** (CWE-502, CVSS 5.0) in a 70,000+ install plugin, tracing anonymous form input to an **unserialize** sink on the server that stored user records.
- Confirmed **remote-code-execution** impact on a clean bench by chaining a companion-plugin gadget to arbitrary file deletion, disclosed through **WPScan** with the CVE assigned.

PROFESSIONAL EXPERIENCE

Cybertrust America | Cybersecurity Analyst - Penetration Tester

Sep 2025 – Jun 2026

- Weaponized a single crafted **prompt injection** into a novel **Denial-of-Wallet** attack on a production **RAG** app, one of 4+ findings, running the abuse end-to-end through Burp Suite.
- Extracted private user data by chaining prompt injection through **data exfiltration** into downstream **privilege escalation** on production LLM orchestration, evidencing each **privacy weakness** with Python PoCs.
- Defeated session invalidation on a multi-tenant SaaS platform via a **JWT** lifecycle flaw that kept tokens valid past logout, exposing user data during a **red team** engagement.
- Bypassed production AI guardrails by scripting Python attack suites that reproduced **jailbreak** and insecure **tool-call authorization** breaks, mapping each to the **OWASP LLM Top 10**.
- Exposed user-record leakage through unvalidated sinks and hardcoded secrets in production LLM orchestration code, auditing data flows with **Snyk** and custom **static analysis**.
- Accelerated cross-functional remediation across recurring **campaign-style** red team operations by pairing reproducible **proof-of-concept** exploits with CVSS-scored guidance for engineering and product teams.

Handshake AI | AI Trainer - Cybersecurity Expert (Contract)

Nov 2025 – Mar 2026

- Improved detection of dual-use requests across 3 misuse categories by running structured **adversarial** probing on hosted-model outputs in **Python**, scoring each bypass for real-world exploitability.
- Advanced red-team coverage of model evasion by running multi-turn **PyRIT** campaigns across 4 adversarial classes including **context leakage**, benchmarked against MITRE ATLAS.
- Delivered ethical-AI safeguards for 3 engineering teams by turning **garak** findings into reproducible **guardrail** fixes with quality and accuracy reviews before deployment.

University of Maryland, College Park | Red Team Analyst

Aug 2024 – May 2025

- Exploited broken authentication and access-control logic to reach other users' data across production web apps, delivering working **exploit** payloads through **penetration tests** with Metasploit.
- Pivoted across enterprise **Linux and Windows** hosts by chaining service misconfigurations and exposed credentials into multi-host footholds during **network reconnaissance** with Nmap.
- Reduced repeat setup across recurring assessments by writing custom Python **automation** that standardized enumeration, **exploit-validation**, and reporting.

DXC Technology | Offensive Security Engineer

Jun 2022 – Aug 2023

- Captured domain-admin control of a test **Active Directory** estate by linking **BloodHound** paths and **Kerberoasting** with Mimikatz credential theft across recurring engagements.
- Contained exposure across 100+ Linux and Windows hosts by triaging **threat-emulation** results from **Nessus** and Nmap against CVSS, exploitability, and asset criticality.
- Exposed user-awareness and email-security gaps enterprise-wide by launching **phishing** and **social engineering** simulations in GoPhish with pretext-based payload delivery.
- Resolved 25+ critical **injection** and **broken access control** defects across web, mobile, and API clients by proving each exploit, cutting live security incidents 35%.

Verzeo | Web Application Penetration Tester

Oct 2021 – Jun 2022

- Breached 8+ production modules to pull private backend records via **SQL injection** in **sqlmap**, chaining stored **cross-site scripting** and IDOR with hand-built payloads.
- Modeled the enterprise external attack surface across VPN, **firewall**, and mail-server controls via Nmap reconnaissance, risk-ranking network fixes against **PCI DSS** and NIST.
- Uncovered broken authentication and **API security** flaws across high-risk production modules by correlating manual **source code review** with proxied traffic in **Burp Suite**, pinning each vulnerable route.

PROJECTS

Pentigo | Python, LangGraph, FastAPI, Ollama, Metasploit, Nmap

- Built an autonomous **LangGraph** agent in Python sequencing recon, scanning, enumeration, and exploitation as dependency-gated phases so it scopes follow-ups like a **red-teamer**.
- Connected **Metasploit**, **Nmap**, **sqlmap**, and **ffuf** through one tool-calling layer that forwards findings across phases, letting exploitation reuse harvested credentials automatically.

ReconX | Python, Nuclei, httpx, Subfinder, AI (Ollama / OpenAI / Groq)

- Developed an **AI-powered 16-stage** reconnaissance orchestrator for bug bounty and penetration testers, with strict deduplication, alive-gating, and scope enforcement at every stage.
- Wired in **AI triage** scoring parameters by injection risk (**0.0 to 1.0**) to eliminate false positives, outputting JSONL, markdown, CSV, and Burp Suite integrations.

SKILLS

Offensive Security & Red Teaming: Red team operations, campaign-style red team operations, offensive privacy testing, penetration testing, vulnerability research, product security, exploit chain development, attack-surface enumeration, privilege escalation, social engineering, phishing

AI Red Teaming & LLM Exploitation: Prompt injection (direct and indirect), jailbreak and refusal bypass, insecure tool-call authorization, agentic access-control bypass, data-exfiltration chains, multi-agent abuse paths, RAG pipeline attacks, AI-driven offensive agents

Privacy & Data Protection: Offensive privacy testing, privacy-weakness exploitation, unauthorized data access, data-exfiltration, user-data exposure, access-control and authorization testing, IDOR and BOLA, session and identity abuse

AI / LLM Security: Responsible and ethical AI practices, guardrail evaluation, adversarial test-suite design, Denial-of-Wallet attack design, quality and accuracy reviews, OWASP LLM Top 10, MITRE ATLAS, PyRIT, garak

Application & API Security: Manual web and API exploitation, secure code review, static and dynamic analysis, SAST/DAST, JWT and session flaws, authentication and authorization bypass, OWASP Top 10

Programming & Tooling: Python, JavaScript, Bash, PowerShell, SQL, custom offensive-tool development, agent orchestration, AI-assisted coding tools

Security Tools & Frameworks: Burp Suite, Metasploit, Nmap, Nessus, sqlmap, ffuf, BloodHound, Mimikatz, Snyk, garak, PyRIT, MITRE ATT&CK

CERTIFICATIONS

Offensive Security Certified Professional (OSCP) – Offensive Security (Pursuing) | eJPT – INE | CompTIA Security+ | Certified Ethical Hacker (CEH) – EC-Council

EDUCATION

University of Maryland, College Park | Master of Engineering, Cybersecurity

Aug 2023 – May 2025

Coursework: Cloud Security, Reverse Engineering, Digital Forensics, Network Security, Cryptography, Operating Systems.